

NorthBridge Technology Solutions Inc.
Information Security Management System

ISMS Scope and Context Statement
NB-ISMS-001

DOCUMENT CONTROL	
Document Title	ISMS Scope and Context Statement
Document ID	NB-ISMS-001
Version	1.0
Date	05/18/2026
Author	Ashkon Irani
Reviewed By	IT Director
Approved By	Chief Executive Officer
Classification	Confidential
Review Frequency	Annual, or following any significant change to organizational context or ISMS scope
Related Documents	NB-ISMS-002, NB-ISMS-003, NB-ISMS-004, NB-ISMS-005, POL-001
ISO 27001 Clauses	4.1, 4.2, 4.3, 6.2

1. Purpose

The purpose of this document is to define the organizational context and scope of the Information Security Management System (ISMS) at NorthBridge Technology Solutions Inc., in accordance with Clause 4 of the ISO/IEC 27001:2022 standard. This document establishes the internal and external factors relevant to information security, identifies interested parties and their requirements, formally defines the boundaries of the ISMS, and sets out the measurable information security objectives against which NorthBridge's security performance will be assessed.

This document is the foundational reference for the entire NorthBridge ISMS. All subsequent risk assessments, control decisions, policy statements, and audit activities must be consistent with the scope and context defined here. Any change to the organizational context, business environment, or technology landscape that affects the ISMS must be reflected in a formal review and update of this document.

2. Organizational Context (Clause 4.1)

ISO 27001:2022 Clause 4.1 requires NorthBridge to understand the internal and external factors that influence its ability to achieve the intended outcomes of its ISMS. These factors shape the threat landscape the organization operates in, the regulatory obligations it must satisfy, and the security controls it must implement.

2.1 Internal Context

NorthBridge Technology Solutions Inc. is a 220-person federal IT consulting firm headquartered in Ottawa, Ontario. The organization provides cloud migration, managed IT services, and custom software development to Government of Canada clients. Internally, NorthBridge operates the following key technology environments:

- Microsoft Azure (Canada East primary, Canada Central disaster recovery) hosting all client workloads and internal application servers
- Microsoft 365 tenant for all internal and client-facing communications, document management, and collaboration
- Azure DevOps for source code management and CI/CD pipeline operations
- Cisco AnyConnect VPN providing secure remote access for all remote and travelling employees
- ServiceNow for IT service management, incident ticketing, and change management
- BambooHR for employee HR records and payroll integration
- 1Password Teams for secure credential management across the IT team

NorthBridge employs a distributed workforce with the majority of staff working in a hybrid model combining office attendance at the Ottawa headquarters with remote working. The IT team consists of four senior administrators holding Secret security clearance. The development team consists of twelve developers with access to source code repositories and government-deployed software pipelines.

2.2 External Context

Externally, NorthBridge operates in a highly regulated environment shaped by the following factors:

- Government of Canada security requirements including the Policy on Government Security, Treasury Board Secretariat directives, and the ITSG-33 IT Security Risk Management framework published by the Canadian Centre for Cyber Security. All active NorthBridge contracts require compliance with these frameworks.
- The Personal Information Protection and Electronic Documents Act (PIPEDA), which governs NorthBridge's obligations regarding the personal information of its 220 employees and any personal data processed on behalf of clients.
- Contractual security clauses embedded in all active GoC client agreements, including Protected B data handling requirements, mandatory incident notification timeframes, and client rights to audit NorthBridge's security practices.
- An evolving external threat landscape characterized by increasing ransomware attacks targeting government supply chains, phishing campaigns directed at federal contractors with privileged access to government systems, and growing nation-state interest in Canadian government IT infrastructure.

- The Government of Canada's ongoing modernization of its supply chain security requirements following high-profile contractor breaches, which is increasing the security maturity bar required to maintain and win government contracts.

3. Interested Parties and Their Requirements (Clause 4.2)

ISO 27001:2022 Clause 4.2 requires NorthBridge to identify the parties who have an interest in its information security practices and to understand what those parties require or expect. Failure to understand and address stakeholder requirements creates gaps in the ISMS that will surface during audits, incidents, or client reviews.

The following table identifies all key interested parties relevant to the NorthBridge ISMS, their relationship to the organization, and their specific information security requirements.

Interested Party	Relationship	Information Security Requirements and Expectations
Government of Canada Clients	Primary clients	Protected B data handled exclusively within approved Canadian environments. Compliance with ITSG-33 security controls. Mandatory written notification within 24 hours of a confirmed breach involving client data. Right to audit NorthBridge's security practices at any time with reasonable notice. Security clearance maintained by all staff with client access.
NorthBridge Employees	Internal workforce	Personal HR and payroll data are protected in accordance with PIPEDA. Clear communication of security responsibilities and acceptable use requirements. A safe working environment free from insider surveillance beyond what is disclosed in policy. Timely notification if their personal data is involved in a security incident.
Subcontractors and Contractors	Third-party delivery partners	Secure data sharing protocols and clearly defined security obligations in contract terms. Timely communication of security incidents relevant to their work. Clear guidance on acceptable use of NorthBridge systems during their engagement.
Canadian Centre for Cyber Security (CCCS)	Regulatory and guidance body	Adherence to ITSG-33 and applicable Government of Canada security frameworks. Voluntary incident reporting for significant cyber incidents affecting federal contractor environments.
Office of the Privacy Commissioner (OPC)	Privacy regulator	PIPEDA compliance in the collection, use, and protection of employee and client personal information. Prompt notification of reportable breaches posing a real risk of significant harm to affected individuals.
NorthBridge Executive Leadership	Internal governance	Business continuity and protection of revenue-generating client relationships. Demonstrable security due diligence to support contract renewals and new business development. Liability management and reputation protection. Clear visibility of the organization's risk of posture.
Cyber Insurance Provider	Financial risk transfer partner	Evidence of implemented security controls consistent with the policy representations made at underwriting. Prompt notification of incidents meeting the reporting threshold in

		the insurance policy. Maintenance of controls required as a condition of coverage.
External Auditors	ISO 27001 certification body	Documented and implemented ISMS consistent with ISO 27001:2022 requirements. Evidence of risk assessment, treatment, and monitoring activities. Management commitment and continuous improvement.

4. ISMS Scope Statement (Clause 4.3)

ISO 27001:2022 Clause 4.3 requires NorthBridge to formally define the boundaries of the ISMS. The scope statement below has been reviewed and approved by executive leadership. All risk assessments, controls, policies, and audit activities apply exclusively to the assets, systems, processes, and personnel within this scope.

FORMAL ISMS SCOPE STATEMENT

The ISMS of NorthBridge Technology Solutions Inc. apply to all information assets, processes, systems, personnel, and facilities involved in the delivery of IT consulting and managed services to Government of Canada clients, including the protection of Protected B information processed under federal contracts.

The scope encompasses: the Microsoft Azure cloud environment (Canada East and Canada Central regions) used to host client workloads; the Microsoft 365 tenant used for internal and client-facing communications and document management; the Azure DevOps environment used for source code management and software deployment pipelines; all endpoints (laptops and mobile devices) enrolled in the NorthBridge Microsoft Intune MDM system; the Cisco AnyConnect VPN infrastructure; the Ottawa headquarters facility at 350 Sparks Street including the server room on Floor 2; all full-time employees, part-time employees, and contracted staff who handle Protected B information or have access to systems within this scope.

4.1 Explicit Exclusions

The following are explicitly excluded from the ISMS scope. Exclusions are documented with justification to ensure that auditors and stakeholders can confirm each exclusion is appropriate and does not create unacceptable risk to in-scope assets.

Excluded Item	Justification for Exclusion
Personal devices not enrolled in NorthBridge MDM	Personal devices that have not been enrolled in Microsoft Intune are not managed by NorthBridge and cannot be subject to NorthBridge security controls. Staff are prohibited from using unenrolled personal devices to access NorthBridge systems under POL-002.
Third-party HR and payroll processing conducted solely within BambooHR's own environment	BambooHR operates its own ISO-aligned security program and processes NorthBridge HR data under a data processing agreement. BambooHR's internal systems are outside NorthBridge's control boundary and are managed through the vendor risk program under POL-005.

NorthBridge finance and accounting systems that do not process client data	QuickBooks Enterprise is used solely for internal financial management and does not process Government of Canada client data. It falls outside the primary risk boundary of the ISMS. It is included in the Asset Inventory for completeness but is not subject to the ISMS audit scope.
Public marketing and communications activities	NorthBridge's public-facing website, marketing materials, and public social media accounts do not involve Protected B data or systems connected to client environments and are therefore outside the ISMS scope.

5. Information Security Objectives (Clause 6.2)

ISO 27001:2022 Clause 6.2 requires NorthBridge to establish measurable information security objectives that are consistent with the information security policy, account for applicable requirements, and are monitored and updated as needed. The objectives below are reviewed quarterly by the IT Director and presented to executive leadership at the annual ISMS management review.

Each objective has a defined measure, a target, a named owner, and a review of frequency. Objectives without these four components are wishes, not commitments.

#	Objective	Measure	Target	Owner	Review
1	Protect the confidentiality of Protected B Government of Canada client data from unauthorized disclosure	Number of confirmed unauthorized disclosures of Protected B data per year	Zero confirmed unauthorized disclosures in any 12-month period	IT Director	Quarterly
2	Ensure all staff complete mandatory information security awareness training	Percentage of staff who have completed annual security awareness training	100% completion within 30 days of hire and annually thereafter	HR Manager	Quarterly
3	Maintain availability of client-facing systems in accordance with contractual SLAs	System availability percentage for all Tier 1 client workloads hosted in Azure	At or above the availability threshold specified in each active GoC client contract	IT Director	Monthly
4	Ensure all High and Critical residual risks have active treatment plans	Number of High or Critical residual risks in the Risk Register without a documented, approved treatment plan	Zero High or Critical residual risks without an active treatment plan at any point	IT Director	Quarterly

5	Comply with all applicable regulatory and contractual security requirements	Number of regulatory findings or client audit failures per year	Zero regulatory findings or client audit failures in any 12-month period	IT Director	Annual
6	Detect and escalate P1 security incidents within defined timeframes	Percentage of P1 incidents escalated to the Incident Commander within 1 hour of detection	100% of P1 incidents escalated within 1 hour of detection	IT Manager	Per incident
7	Reduce staff susceptibility to phishing attacks	Percentage of staff clicking links in simulated phishing exercises	Phishing susceptibility rate below 5% within 6 months of program launch	HR Manager	Quarterly
8	Ensure all Tier 1 and Tier 2 vendors are assessed and operating under security-compliant contracts	Percentage of Tier 1 and Tier 2 vendors with a current security assessment and compliant contract	100% of Tier 1 and Tier 2 vendors assessed and contracted within 12 months	IT Director	Annual

6. ISMS Leadership and Governance

The following roles hold specific accountability for the establishment, implementation, maintenance, and continual improvement of the NorthBridge ISMS. These designations are made in accordance with ISO 27001:2022 Clause 5.3.

Role	ISMS Governance Accountability
Chief Executive Officer	Ultimate accountability for the ISMS and the organization's risk of posture. Approves the ISMS scope, risk acceptance criteria, and information security policy. Provides visible leadership commitment to information security. Reviews ISMS performance at the annual management review. Approves significant risk acceptance decisions and security investments.
IT Director (ISMS Owner)	Day-to-day responsibility for operating and maintaining the ISMS. Maintains all ISMS documentation. Ensures the Risk Register is current, and treatment plans are being executed. Chairs on the security committee. Escalates Critical risks and P1 incidents to the CEO. Reports ISMS performance metrics to leadership quarterly.
IT Manager	Operational execution of security controls including access management, patch management, endpoint security, and vendor access provisioning. Supports the IT Director in incident response and risk assessment activities.
HR Manager	Accountable for security obligations in employment contracts, onboarding, offboarding, and staff training completion. Works with IT Director on insider threat investigations.
All Asset Owners	Named in the Asset Inventory (NB-ISMS-002). Accountable for ensuring assets under their ownership are adequately protected, and that risks associated with their assets are reviewed and treated.

7. Relationship to Other ISMS Documents

This document is the root of the NorthBridge ISMS documentation hierarchy. The following diagram shows how the ISMS documents relate to one another and to this scope statement.

Document ID	Title	How It Relates to This Document
NB-ISMS-002	Asset Inventory	Identify and classify all assets within the scope defined in Section 4 of this document.
NB-ISMS-003	Risk Assessment Methodology	Defines the rules used to assess risks to the assets and processes within this ISMS scope.
NB-ISMS-004	Risk Register	Documents all risks identified against assets within this scope, using the methodology in NB-ISMS-003.
NB-ISMS-005	Statement of Applicability	Records NorthBridge's decisions regarding each ISO 27001:2022 Annex A control, justified against the scope and context defined here.
POL-001	Information Security Policy	The top-level policy expresses NorthBridge's commitment to protecting assets within this scope.
POL-002	Acceptable Use Policy	Governs how personnel within this scope may use the assets identified in NB-ISMS-002.
POL-003	Access Control Policy	Defines access requirements for all systems within this ISMS scope.
POL-004	Incident Response Policy	Defines how NorthBridge responds to incidents affecting assets within this scope.
POL-005	Vendor Management Policy	Governs third-party vendors who access assets within this scope.

8. Document Review and Approval

This document shall be reviewed annually by the IT Director and approved by the Chief Executive Officer. Reviews shall also be triggered by any of the following:

- A significant change to NorthBridge's organizational structure, business model, or client base
- A material changes to the technology environment within the ISMS scope
- A new or amended legal, regulatory, or contractual requirement affecting the scope or context of the ISMS
- A finding from an internal or external audit that requires a change to the scope statement or organizational context
- A significant security incident that reveals gaps in the scope definition

Any change to the ISMS scope that reduces coverage -- for example, removing a system or process from scope -- requires written approval from the Chief Executive Officer and must be communicated to all relevant GoC clients where contractual security obligations may be affected.

Role	Name	Signature	Date
Author	Ashkon Irani	[Signed]	05/18/2026
Reviewer	IT Director	[Signed]	05/18/2026
Approver	Chief Executive Officer	[Signed]	05/18/2026

-- End of Document --

NB-ISMS-001 v1.0 | NorthBridge Technology Solutions Inc. | CONFIDENTIAL